

PROJETO FINAL · COMPUTAÇÃO EM NUVEM

Documento de Arquitetura

Projeto 01 — FarmaVida — E-commerce de Alta Disponibilidade

Pós-Graduação	Engenharia de Software com foco em DevOps · UNIFOR · 2026.2
Professor	Prof. Bruno Vinícius Barroso Cavalcanti
Grupo	ADDR
Integrantes	Alexandre Morlin
	Daniel Azevedo
	Dheyne Sena
	Rafael Oliveira
Data da entrega	03/10/2026

Sumário

1. Identificação	3
2. Resumo Executivo.....	3
3. Contexto e Requisitos	3
3.1 Requisitos funcionais	3
3.2 Requisitos não funcionais	3
3.3 Premissas e restrições	4
4. Escolha do Provedor	4
4.1 Matriz de decisão ponderada (notas 1 a 5)	4
4.2 Registro de decisão (ADR).....	5
5. Arquitetura Proposta	6
5.1 Componentes.....	7
5.2 Serviços equivalentes em outras nuvens.....	7
6. Topologia de Rede	8
6.1 VPC e subnets	8
6.2 Security Groups	8
6.3 Conectividade externa.....	9
7. Segurança e Identidade	9
7.1 IAM	9
7.2 Controles.....	9
7.3 Responsabilidade compartilhada	10
8. Estratégia de Armazenamento	10
9. Observabilidade e Resiliência	11
10. Custos e FinOps	12
10.1 Otimizações propostas	12
10.2 Governança de custos	13
11. Well-Architected Framework	13
12. Evidências da Implementação	13
13. Riscos, Limitações e Próximos Passos.....	15
14. Referências	15

1. Identificação

Campo	Preenchimento
Projeto	Projeto 01 — FarmaVida — E-commerce de Alta Disponibilidade
Grupo	ADDR
Integrantes	Alexandre Morlin Daniel Azevedo Dheyne Sena Rafael Oliveira
Data da entrega	03/10/2026
Repositório	https://github.com/AMorlin/farmavida-aws-terraform
Região AWS utilizada	us-east-1 (N. Virginia), com entrega ao usuário pelas bordas do CloudFront no Brasil

2. Resumo Executivo

A FarmaVida vende pela internet a partir de **um único servidor** alugado em Fortaleza. Na última Black Friday o site caiu duas vezes, com prejuízo estimado de **R\$ 400 mil**. A proposta leva a loja para a AWS numa arquitetura **sem ponto único de falha**: a loja roda em pelo menos dois servidores, em dois datacenters independentes da mesma região, atrás de um balanceador de carga. O banco de dados mantém uma cópia em tempo real no outro datacenter e assume sozinho se o principal falhar.

Nos picos, o número de servidores cresce automaticamente até **10 vezes** e volta ao normal depois. A empresa só paga pela capacidade extra nos dias em que ela é usada. As imagens dos produtos chegam ao cliente por uma rede de distribuição (CDN) com pontos de presença em Fortaleza e em outras capitais. Os dados dos clientes ficam criptografados com chave própria e todo acesso é registrado, como exige a LGPD.

Custo estimado: cerca de **US\$ 223 por mês** em operação normal e cerca de US\$ 295 no mês da Black Friday. As otimizações propostas podem reduzir esse valor em 15% a 25%. **Principal benefício:** a loja deixa de cair nos picos e continua no ar mesmo com a perda de um datacenter inteiro.

3. Contexto e Requisitos

3.1 Requisitos funcionais

- **RF01** — Catálogo de produtos com imagens, navegação por categoria e busca.
- **RF02** — Carrinho e checkout, com pagamento por gateway externo (a loja não armazena dados de cartão).
- **RF03** — Cadastro e login de clientes, com histórico de pedidos.
- **RF04** — Área administrativa (produtos, preços, estoque e pedidos) acessível **somente** pela rede interna, VPN ou bastion.
- **RF05** — Upload de imagens de produtos pela área administrativa.

3.2 Requisitos não funcionais

Requisito	Meta
Disponibilidade	99,9% (até 8 h 46 min de indisponibilidade por ano), tolerando a perda de uma AZ inteira
Latência	< 300 ms (p95) para páginas dinâmicas e < 100 ms para imagens (CDN), para usuários no Brasil
Volume / escala	10x o tráfego normal em datas promocionais: de 2 para até 20 instâncias, sem intervenção manual

Requisito	Meta
Conformidade	LGPD: dados pessoais e de pagamento criptografados em repouso (KMS) e em trânsito (TLS), com trilha de auditoria de todo acesso
Segurança operacional	Nenhuma porta administrativa (SSH, banco) exposta à internet
Custo	Base de até ~US\$ 250/mês fora dos picos, com alerta de orçamento

3.3 Premissas e restrições

- A aplicação é **stateless**: sessão e carrinho ficam no banco (ou em cookie assinado). Assim, instâncias podem ser criadas e removidas a qualquer momento.
- Os pagamentos são processados por um gateway externo certificado PCI DSS; a loja guarda apenas o token da transação.
- A empresa não tem contratos Microsoft nem Oracle, portanto não há benefício de licenciamento em Azure ou OCI.
- O time tem experiência em Linux e no ecossistema AWS, trabalhado ao longo da disciplina.
- A infraestrutura é descrita em Terraform e validada com `terraform plan`. O ambiente não foi provisionado, por decisão de custo do grupo (ver seção 12).
- Nesta fase há uma única região (us-east-1). Recuperação de desastre multirregião fica como próximo passo.

4. Escolha do Provedor

4.1 Matriz de decisão ponderada (notas 1 a 5)

Critério	Peso	AWS	Azure	Google Cloud	OCI
Aderência técnica	20%	5	5	4	3
Custo total (TCO)	20%	4	4	4	5
Segurança & compliance	15%	5	5	4	4
Região / latência	10%	4	4	4	3
Skills do time	15%	5	3	2	1
Contratos & licenças	5%	4	3	4	3
Suporte & ecossistema	10%	5	4	3	2
Lock-in / portabilidade	5%	2	2	3	3
Total ponderado	100%	4,50	4,05	3,55	3,15

Critérios das notas:

- **Aderência técnica:** AWS e Azure têm equivalentes maduros para todos os blocos (CDN, balanceador L7, autoscaling, PostgreSQL gerenciado com HA entre zonas). O GCP também atende, com menos opções de PostgreSQL gerenciado. Na OCI, a CDN depende de parceiro.
- **Custo:** preços de computação semelhantes entre AWS, Azure e GCP. A OCI é a mais barata em computação e tráfego de saída.
- **Região / latência:** os quatro têm região em São Paulo. A nota considera também a rede de bordas de CDN no Nordeste (CloudFront e Azure Front Door têm presença em Fortaleza).
- **Skills do time:** toda a disciplina foi feita em AWS. As outras nuvens exigiriam capacitação antes da migração.
- **Contratos:** sem contratos Microsoft ou Oracle, Azure e OCI perdem a principal vantagem comercial que teriam (Hybrid Benefit e licenças Oracle).

- **Lock-in:** o uso de serviços gerenciados prende mais à AWS e à Azure. Isso é mitigado com Terraform e PostgreSQL padrão (portável).

4.2 Registro de decisão (ADR)

- **Contexto:** e-commerce com picos de 10× o tráfego e exigência de 99,9%, sem contratos Microsoft ou Oracle. O brief pede comparar AWS × Azure e avaliar se a região São Paulo compensa o custo maior em relação à us-east-1.
- **Decisão:** AWS na região **us-east-1**, com o **CloudFront** atendendo os clientes pelas bordas brasileiras (Fortaleza, Rio, São Paulo) e terminando o TLS perto do usuário.
- **Alternativas consideradas:** (1) Azure Brazil South, com equivalentes maduros (Front Door, Application Gateway, VM Scale Sets, PostgreSQL Flexible Server com HA por zona), mas sem vantagem de licença e com menor domínio do time; (2) Google Cloud e OCI, com menor aderência de skills e de ecossistema; (3) AWS **sa-east-1**, com menos latência nas páginas dinâmicas (~20–40 ms contra ~120 ms), mas custo estimado de **~US\$ 360/mês, cerca de 60% acima** (o NAT Gateway, por exemplo, custa o dobro por hora).
- **Consequências (prós):** menor custo mensal, maior catálogo de serviços, documentação e comunidade, e domínio do time.
- **Consequências (contras):** os dados pessoais ficam fora do Brasil. Isso exige base legal de transferência internacional pela LGPD (art. 33, cláusulas-padrão contratuais da Resolução CD/ANPD nº 19/2024, já presentes no DPA da AWS). As páginas dinâmicas têm latência maior, mitigada pelo CloudFront e mantida abaixo de 300 ms. Há lock-in moderado. **Gatilho de revisão:** se o jurídico ou a ANPD exigirem residência de dados no Brasil, a migração para sa-east-1 é uma troca da variável **region** mais a migração do banco.

5. Arquitetura Proposta

FarmaVida — E-commerce de Alta Disponibilidade

CloudFront → ALB → Auto Scaling em 2 AZs → RDS PostgreSQL Multi-AZ · imagens no S3 via CloudFront (OAC) · tudo criptografado com KMS

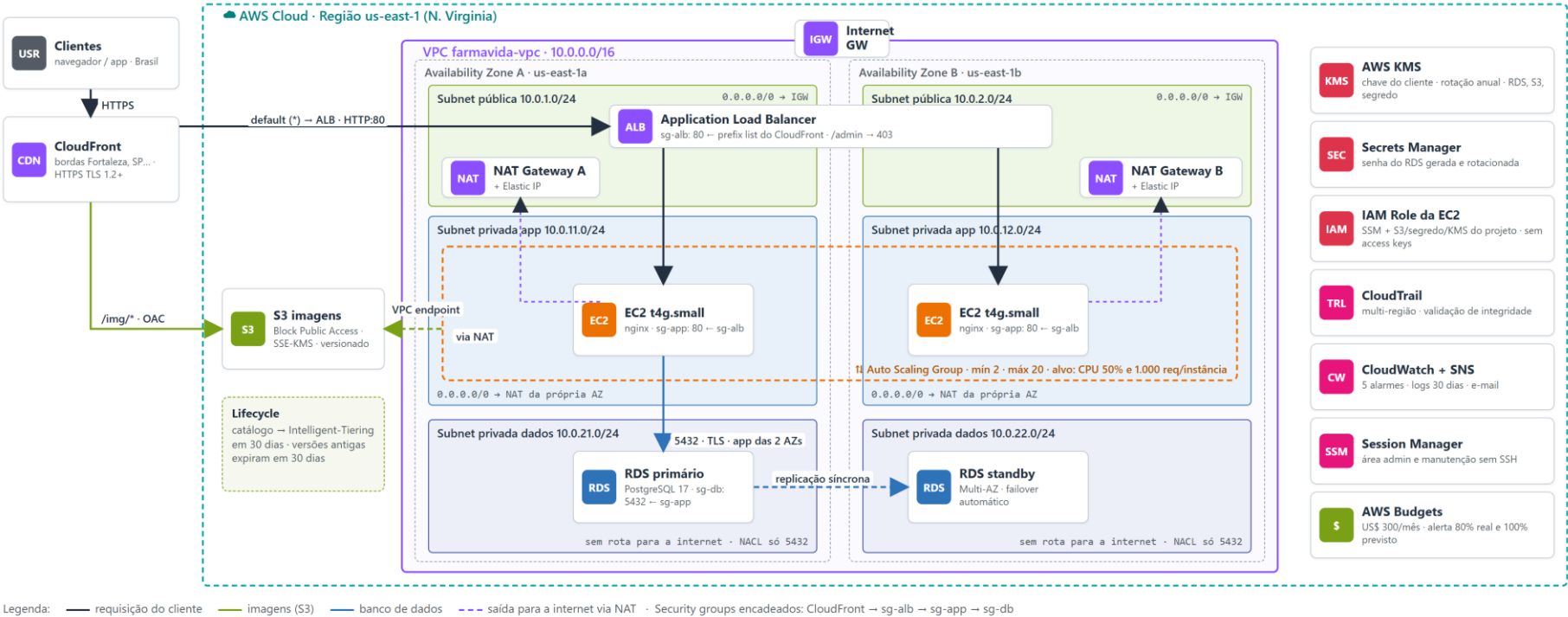


Figura 1 — Arquitetura da FarmaVida na AWS (arquivo-fonte: diagramas/arquitetura.png). Cada camada só aceita tráfego da camada anterior.

5.1 Componentes

Componente	Serviço AWS	Função na solução
Borda / CDN	Amazon CloudFront	HTTPS para o cliente (TLS 1.2+), cache das imagens (/img/*) e encaminhamento do restante ao ALB. Bordas em Fortaleza, Rio e São Paulo.
Balanceamento	Application Load Balancer	Distribui as requisições entre as instâncias das 2 AZs, faz health check em /health e bloqueia /admin (403).
Computação	EC2 t4g.small (Graviton) + Auto Scaling Group	Servidores web/app stateless, de 2 a 20 instâncias. Escala por CPU (50%) e por requisições (1.000 por instância).
Padrão das instâncias	Launch Template (Amazon Linux 2023 arm64 + user_data)	Instâncias idênticas, IMDSv2 obrigatório, disco gp3 criptografado, atualização por instance refresh.
Banco de dados	Amazon RDS PostgreSQL 17 Multi-AZ (db.t4g.small)	Pedidos, clientes e estoque. Standby síncrono na outra AZ, failover automático, backups de 7 dias.
Imagens do catálogo	Amazon S3	Objetos privados, lidos apenas pelo CloudFront via Origin Access Control (OAC).
Rede	VPC, subnets, Internet Gateway, 2 NAT Gateways, VPC endpoint S3	Isolamento em 3 camadas. A camada de app sai para a internet pelo NAT da própria AZ.
Chaves	AWS KMS	Chave do cliente, com rotação anual, para RDS, S3, CloudTrail e o segredo do banco.
Segredos	AWS Secrets Manager	Senha do banco gerada e rotacionada pelo próprio RDS.
Identidade	IAM Role + Instance Profile	Permissões mínimas para as instâncias, sem access keys.
Acesso administrativo	AWS Systems Manager Session Manager	Shell e port forwarding até a área administrativa, sem SSH e sem bastion.
Auditoria	AWS CloudTrail	Registro de todas as chamadas de API, multirregião, com validação de integridade.
Observabilidade	Amazon CloudWatch + Amazon SNS	Métricas, logs e 5 alarmes com aviso por e-mail.
Custos	AWS Budgets	Orçamento mensal com alertas de gasto real e previsto.

5.2 Serviços equivalentes em outras nuvens

Serviço AWS usado	Azure	Google Cloud	OCI
CloudFront	Azure Front Door	Cloud CDN	OCI CDN (parceiro Akamai)
Application Load Balancer	Application Gateway	Cloud Load Balancing (HTTP(S))	OCI Load Balancer
EC2 + Auto Scaling Group	VM Scale Sets	Managed Instance Groups	Instance Pools + Autoscaling
RDS PostgreSQL Multi-AZ	Azure Database for PostgreSQL – Flexible Server (HA por zona)	Cloud SQL for PostgreSQL (HA regional)	OCI Database with PostgreSQL
S3	Blob Storage	Cloud Storage	Object Storage
VPC / NAT Gateway	Virtual Network / NAT Gateway	VPC / Cloud NAT	VCN / NAT Gateway
KMS / Secrets Manager	Key Vault	Cloud KMS / Secret Manager	OCI Vault
IAM Role (instância)	Managed Identity	Service Account	Instance Principal (Dynamic Group)
Session Manager	Azure Bastion	IAP TCP forwarding	OCI Bastion
CloudTrail	Activity Log	Cloud Audit Logs	OCI Audit

Serviço AWS usado	Azure	Google Cloud	OCI
CloudWatch + SNS	Azure Monitor + Action Groups	Cloud Monitoring + Alerting	OCI Monitoring + Notifications
AWS Budgets	Cost Management Budgets	Cloud Billing Budgets	OCI Budgets

6. Topologia de Rede

6.1 VPC e subnets

Nome	CIDR	AZ	Tipo (pública/privada)	Rota padrão
farmavida-vpc	10.0.0.0/16	—	—	—
farmavida-publica-a	10.0.1.0/24	us-east-1a	pública	0.0.0.0/0 → IGW
farmavida-publica-b	10.0.2.0/24	us-east-1b	pública	0.0.0.0/0 → IGW
farmavida-app-a	10.0.11.0/24	us-east-1a	privada (app)	0.0.0.0/0 → NAT-A · S3 → VPC endpoint
farmavida-app-b	10.0.12.0/24	us-east-1b	privada (app)	0.0.0.0/0 → NAT-B · S3 → VPC endpoint
farmavida-dados-a	10.0.21.0/24	us-east-1a	privada (dados)	somente local (sem saída para a internet)
farmavida-dados-b	10.0.22.0/24	us-east-1b	privada (dados)	somente local (sem saída para a internet)

Planejamento de CIDR: cada camada recebe um /24 por AZ (251 IPs utilizáveis), muito acima do máximo de 20 instâncias do ASG. A numeração por faixa (1–2 públicas, 11–12 app, 21–22 dados) deixa espaço para uma terceira AZ (10.0.3/13/23) e para novas camadas sem renumerar. Nenhuma subnet atribui IP público automaticamente. Só o ALB e os NAT Gateways ficam nas subnets públicas.

6.2 Security Groups

Security Group	Origem	Porta/Protocolo	Destino	Justificativa
sg-alb (entrada)	Prefix list <code>com.amazonaws.global.cloudfront.origin-facing</code>	80/TCP	ALB	Só o CloudFront alcança o ALB, então ninguém contorna a CDN nem o TLS da borda
sg-alb (saída)	ALB	80/TCP	sg-app	O ALB só encaminha para as instâncias
sg-app (entrada)	sg-alb	80/TCP	EC2	Instâncias só recebem do ALB. Não há porta 22
sg-app (saída)	EC2	443 e 80/TCP	0.0.0.0/0 (via NAT)	Pacotes do SO e APIs AWS (SSM, CloudWatch, Secrets Manager)
sg-app (saída)	EC2	5432/TCP	sg-db	Acesso ao banco
sg-db (entrada)	sg-app	5432/TCP	RDS	O banco só aceita a camada de aplicação

Todas as regras internas referenciam o **security group** da camada anterior, e não IPs: qualquer instância nova do ASG herda o acesso, e nenhuma outra o recebe. A camada de dados tem também uma **NACL** (segunda barreira,

stateless). Ela permite na entrada apenas 5432/TCP vindo de 10.0.11.0/24 e 10.0.12.0/24, na saída apenas as portas efêmeras (1024–65535) de volta para essas subnets, e o tráfego entre as próprias subnets de dados (10.0.20.0/23). Todo o resto é negado pela regra implícita.

6.3 Conectividade externa

- **Internet Gateway:** a única entrada pública é o ALB, que só aceita o CloudFront. O IGW também serve de saída para os NAT Gateways.
- **NAT Gateway (um por AZ):** dá saída às instâncias privadas (atualizações, SSM, CloudWatch) sem expô-las. Há um por AZ para que a queda de uma zona não derrube a saída da outra.
- **VPC Gateway Endpoint para S3:** o tráfego da aplicação até o S3 não passa pelo NAT. É gratuito, reduz o custo de processamento do NAT e mantém o tráfego na rede da AWS.
- **VPN / Direct Connect:** não utilizados nesta fase. O requisito de área administrativa "somente rede interna/VPN/bastion" é atendido pelo **Session Manager**: túnel TLS autenticado pelo IAM e auditado no CloudTrail, sem porta aberta e sem custo fixo de VPN ou bastion. Uma Site-to-Site VPN para integrar as 120 lojas é próximo passo (seção 13).

7. Segurança e Identidade

7.1 IAM

Identidade (user/role)	Usada por	Permissões (resumo)	Por que é o mínimo necessário
Role <code>farmavida-ec2-app</code> (instance profile)	Instâncias EC2	AmazonSSMManagedInstanceCore; CloudWatchAgentServerPolicy; <code>s3:GetObject/PutObject</code> em <code>farmavida-imagens-*/catalogo/*</code> ; <code>secretsmanager:GetSecretValue</code> no segredo do RDS; <code>kms:Decrypt/GenerateDataKey</code> na chave do projeto	Cada ação se limita ao ARN do recurso do projeto, sem <code>:*</code> . As credenciais são temporárias e rotacionadas automaticamente pelo instance profile, sem access keys
Service principal <code>cloudfront.amazonaws.com</code>	CloudFront (OAC)	<code>s3:GetObject</code> no bucket de imagens e <code>kms:Decrypt</code> , ambos condicionados ao ARN da distribuição	Somente esta distribuição lê o bucket, que é privado
Service principal <code>cloudtrail.amazonaws.com</code>	CloudTrail	<code>s3:PutObject</code> em <code>AWSLogs/<conta>/*</code> e <code>kms:GenerateDataKey</code> com contexto de trilha	A gravação fica restrita ao prefixo da própria conta
Usuário IAM de automação (Terraform)	Operador do grupo	Provisionamento dos serviços do projeto, com MFA	Separado da root; access key só na máquina do operador, nunca no repositório
Grupo IAM de administradores	Integrantes do grupo	Console e <code>ssm:StartSession</code> nas instâncias com a tag <code>Projeto=ecommerce-farmavida</code>	MFA obrigatório. A root não é usada no dia a dia

7.2 Controles

Controle	Implementado?	Como
MFA na conta root e usuários	Sim (procedimento)	MFA na root, que fica guardada e sem uso diário, e em todos os usuários IAM. É configuração da conta e não é gerenciada pelo Terraform
Criptografia em repouso (KMS)	Sim	Chave do cliente <code>alias/farmavida-dados</code> com rotação anual para RDS (dados e snapshots), S3 (SSE-KMS + Bucket Key), segredo do banco e logs do CloudTrail. EBS cifrado com a chave <code>aws/ebs</code>

Controle	Implementado?	Como
Criptografia em trânsito (TLS)	Sim, parcial	Cliente → CloudFront por HTTPS (TLS 1.2+); app → RDS com TLS obrigatório (<code>rds.force_ssl = 1</code>); o bucket nega acesso sem TLS. O trecho CloudFront → ALB fica em HTTP até haver domínio próprio com certificado ACM (seção 13)
CloudTrail ativo	Sim	Trilha multirregião com eventos globais, validação de integridade dos arquivos, logs cifrados com KMS e retenção de 5 anos
Segredos fora do código	Sim	Senha master gerada e rotacionada pelo RDS no Secrets Manager (<code>manage_master_user_password</code>). Nenhuma credencial no repositório; <code>.tfvars</code> e <code>.tfstate</code> estão no <code>.gitignore</code>
Bloqueio de acesso público no S3	Sim	Block Public Access nos dois buckets, ACLs desabilitadas (BucketOwnerEnforced) e leitura somente via OAC
IMDSv2 obrigatório	Sim	<code>http_tokens = required</code> no launch template, o que impede o roubo de credenciais via SSRF no IMDSv1
Sem SSH / bastion exposto	Sim	Não há porta 22 em nenhum security group. O acesso é pelo Session Manager, auditado no CloudTrail

7.3 Responsabilidade compartilhada

Camada	Responsável (AWS / Grupo)
Datacenter, hardware, hypervisor	AWS
Rede física, bordas do CloudFront, infraestrutura gerenciada do RDS, ALB e NAT	AWS
Sistema operacional e patches do banco (PostgreSQL)	AWS, na janela de manutenção definida pelo grupo (domingo, 04h–05h em Fortaleza)
Sistema operacional, patches das instâncias EC2	Grupo (AMI Amazon Linux 2023 atualizada + instance refresh do ASG)
Aplicação e dependências	Grupo
Dados, IAM, configuração de rede	Grupo
Configuração da criptografia (uso das chaves, políticas)	Grupo (a AWS fornece o KMS)

8. Estratégia de Armazenamento

Dado	Serviço	Classe / tipo	Justificativa	Backup / lifecycle
Imagens de produtos	S3	Standard → Intelligent-Tiering após 30 dias (prefixo <code>catalogo/</code>)	Objetos estáticos servidos a milhares de clientes via CDN, com 11 meses de durabilidade. EBS e EFS não servem conteúdo público em escala	Versionamento; versões anteriores expiram em 30 dias; uploads incompletos são limpos em 7 dias
Pedidos, clientes, estoque	RDS PostgreSQL	gp3 20 GB com autoscaling até 100 GB, Multi-AZ	Dados transacionais (ACID) e relacionais em serviço gerenciado com failover automático	Backup automático diário com PITR de 7 dias, snapshot final na exclusão e deletion protection
Sessões e carrinho	RDS (tabela)	—	Mantém as instâncias stateless sem custo extra. ElastiCache fica como evolução	Coberto pelo backup do RDS
Disco das instâncias	EBS	gp3 8 GB, criptografado	Só SO e aplicação; instâncias descartáveis	Sem backup: recriadas pelo launch template, sem estado local

Dado	Serviço	Classe / tipo	Justificativa	Backup / lifecycle
Logs de auditoria	S3 (bucket do CloudTrail)	Standard → Glacier Instant Retrieval após 90 dias	Retenção longa e barata com consulta ocasional	Expiração em 5 anos
Logs da aplicação e do banco	CloudWatch Logs	Retenção de 30 dias	Investigação de incidentes recentes	Expiram em 30 dias
Segredos	Secrets Manager	—	Rotação e auditoria de acesso	Gerenciado pela AWS

Por que não EFS: nenhuma instância precisa de sistema de arquivos compartilhado. As imagens vão direto para o S3 e o estado fica no banco. O EFS só adicionaria custo (~US\$ 0,30/GB-mês) e latência, sem benefício.

- **Falha de instância ou de AZ:** RPO 0 (replicação síncrona Multi-AZ). RTO de ~1–2 min no banco (failover automático) e < 5 min na aplicação (o ALB retira os alvos e o ASG repõe na AZ saudável).
- **Erro humano ou corrupção de dados:** RPO ≤ 5 min (point-in-time recovery). RTO de ~1 h (restauração para nova instância e troca de endpoint).
- **Imagem apagada ou sobrescrita:** RPO 0 (versionamento). RTO de minutos.

RPO: 0 em falha de AZ; ≤ 5 min em restauração de dados. **RTO:** < 5 min em falha de AZ; ~1 h em restauração de dados.

9. Observabilidade e Resiliência

Métrica / log	Onde	Alarme (limite)	Ação
CPUUtilization média do ASG	CloudWatch (AWS/EC2, monitoramento detalhado de 1 min)	> 70% por 5 min	E-mail via SNS (a escala não está dando conta). A escala automática mira 50%
RequestCountPerTarget	CloudWatch (ALB)	Alvo de 1.000 req/instância (target tracking)	Auto Scaling adiciona ou remove instâncias
HTTPCode_Target_5XX_Count	CloudWatch (ALB)	> 10 em 5 min	E-mail via SNS
UnHealthyHostCount	CloudWatch (target group)	> 0 por 3 min	E-mail via SNS. O ASG substitui a instância (health check do ELB)
CPUUtilization do RDS	CloudWatch (AWS/RDS)	> 80% por 10 min	E-mail via SNS; avaliar classe maior ou read replica
FreeStorageSpace do RDS	CloudWatch (AWS/RDS)	< 2 GB	E-mail via SNS (o storage autoscaling atua antes)
Logs do nginx	CloudWatch Logs /farmavida/app/nginx	—	Investigação de incidentes, retidos por 30 dias
Logs do PostgreSQL	CloudWatch Logs (export do RDS)	Consultas > 1 s	Otimização de consultas
Chamadas de API	CloudTrail	—	Auditoria e LGPD
Custo mensal	AWS Budgets	80% do real / 100% do previsto (US\$ 300)	E-mail ao responsável

- **Estratégia Multi-AZ:** todas as camadas estão em duas AZs: ALB em 2 subnets públicas, ASG distribuído nas 2 subnets de app (mínimo de 1 instância por AZ), RDS com standby síncrono e um NAT Gateway por AZ. A perda de uma AZ inteira não tira a loja do ar.

- **Preparação para picos:** além da escala automática, o grupo agenda um *scheduled scaling* (mínimo de 6 instâncias) na véspera da Black Friday, para não depender só da reação das métricas.
- **Plano de recuperação de desastre:** *backup & restore*, com Multi-AZ para falhas de zona e PITR para falhas de dados. A evolução para *pilot light* em sa-east-1 (cópia de snapshots + Terraform pronto para subir a região) está na seção 13.

10. Custos e FinOps

- **Link do AWS Pricing Calculator:**

<https://calculator.aws/#/estimate?id=e2d869487caa3e3ed607fda5c95d65d5f94e26eb>

Estimativa em us-east-1, preços On-Demand, 730 h/mês, com os valores do AWS Pricing Calculator (link acima, de 05/10/2026). O monitoramento detalhado das instâncias está somado na linha do CloudWatch.

Componente	Configuração	Custo mensal (US\$)
EC2 (base do ASG)	2× t4g.small On-Demand	24,53
EBS	2× gp3 8 GB	1,28
Application Load Balancer	730 h + ~2 LCU em média	28,11
NAT Gateway	2× (730 h) + 100 GB processados	70,20
IPv4 públicos	4 endereços (2 Elastic IPs dos NAT + 2 do ALB)	14,60
RDS PostgreSQL	db.t4g.small Multi-AZ	47,45
RDS storage	20 GB gp3 Multi-AZ (backup até 100% do banco sem custo)	4,60
S3	50 GB Standard + requisições	1,80
CloudFront	500 GB e 20 M req. HTTPS/mês no Brasil (1 TB e 10 M req. no free tier permanente)	22,00
KMS	1 chave + ~100 mil requisições	1,30
Secrets Manager	1 segredo	0,40
CloudWatch	5 alarmes, monitoramento detalhado (2 instâncias), ~5 GB de logs	7,22
CloudTrail, SNS, Budgets, endpoint S3, Session Manager	1ª trilha, e-mails, 2 budgets, gateway endpoint e SSM sem custo (o storage dos logs, ~US\$ 0,10, fica fora da calculadora)	0,00
Total (mês normal)		223,49

Mês da Black Friday: 18 instâncias extras por 72 h (+US\$ 21,77), mais LCUs no ALB (+US\$ 10,37) e mais requisições no CloudFront (+US\$ 39,60), totalizando ≈ **US\$ 295**. O NAT Gateway, sozinho, é ~31% do custo base: é o preço de manter uma saída por AZ. **A mesma arquitetura em sa-east-1** sairia por ≈ **US\$ 360/mês** (seção 4.2).

10.1 Otimizações propostas

Otimização	Economia estimada	Trade-off
Um único NAT Gateway, em vez de um por AZ	~US\$ 36,50/mês (~16%)	Se a AZ do NAT cair, a outra AZ perde saída para a internet (atualizações, SSM). O site continua no ar, porque o tráfego dos clientes entra pelo ALB
Compute Savings Plan de 1 ano, sem adiantamento, para as 2 instâncias base	~25–30% em EC2 (~US\$ 6,60/mês)	Compromisso de gasto por hora durante 1 ano
Instância reservada do RDS por 1 ano (Multi-AZ)	~30% no RDS (~US\$ 14/mês)	Compromisso com a classe. Fazer rightsizing antes de comprar

Otimização	Economia estimada	Trade-off
Spot para a capacidade de pico (mixed instances: 2 On-Demand fixas + Spot acima disso)	Até -70% nas instâncias extras da Black Friday	Interrupção com 2 min de aviso; diversificar tipos (t4g, m7g, c7g)
Graviton (t4g / db.t4g), já aplicado	~20% contra t3 / db.t3 equivalentes	Exige pacotes arm64 (suportados pelo Amazon Linux 2023)
S3 Intelligent-Tiering + expiração de versões, já aplicado	Até ~40% no storage das imagens pouco acessadas	Taxa de monitoramento por objeto acima de 128 KB
Rightsizing com o Compute Optimizer após 30 dias	Variável	Exige histórico de métricas

Somando as três primeiras, o custo base cai para **≈ US\$ 166/mês (-25%)**.

10.2 Governança de custos

- **Tags obrigatórias:** `Projeto=ecommerce-farmavida`, `Grupo`, `Ambiente=projeto-final`, `Owner` e `ManagedBy=terraform`. São aplicadas pelo `default_tags` do provider em todos os recursos, e o ASG as propaga para instâncias e volumes. A tag `Projeto` deve ser ativada como *cost allocation tag* no Billing.
- **AWS Budgets:** US\$ 300/mês, filtrado pela tag `Projeto`. Alerta a 80% do gasto real (US\$ 240) e a 100% do previsto, enviado para o e-mail do responsável (variável `owner` do Terraform).
- **Rotina:** revisão mensal no Cost Explorer por tag e `terraform destroy` em qualquer ambiente de teste ao fim de cada sessão.

11. Well-Architected Framework

Pilar	Como a solução atende
Excelência Operacional	Toda a infraestrutura em Terraform (versionada, revisável e reproduzível); instâncias idênticas pelo launch template; atualização sem downtime por instance refresh; acesso operacional auditado pelo Session Manager; alarmes com dono definido
Segurança	Defesa em camadas (CloudFront → sg-alb → sg-app → sg-db + NACL); nada sensível exposto à internet; menor privilégio no IAM, sem access keys nas instâncias; KMS com rotação; TLS; segredos no Secrets Manager; CloudTrail com validação de integridade; IMDSv2
Confiabilidade	Multi-AZ em todas as camadas; health checks com substituição automática; failover automático do banco; escala automática para 10x; backups com PITR; RPO e RTO definidos
Eficiência de Performance	CDN com bordas no Brasil para imagens e TLS; escala por CPU e por requisições; instâncias Graviton; PostgreSQL com storage gp3 e autoscaling de disco; monitoramento de 1 min
Otimização de Custos	Elasticidade (paga o pico só quando há pico); Graviton; Intelligent-Tiering; endpoint S3 para reduzir o processamento no NAT; tags de custo e Budget; plano de Savings Plan, RI e Spot
Sustentabilidade	Graviton consome menos energia por desempenho; capacidade ajustada à demanda real (sem servidores ociosos fora dos picos); cache na borda reduz requisições à origem; dados frios migram para classes mais eficientes

12. Evidências da Implementação

O grupo decidiu **não provisionar** o ambiente na AWS: a conta não tem free tier, e NAT Gateways, ALB e RDS Multi-AZ cobram por hora. A implementação está **completa em Terraform** (`infra/terraform/`, com arquivos separados para rede, segurança, armazenamento, computação, CDN e observabilidade). Ela foi **validada** com `terraform validate` e com um `terraform plan` executado contra uma conta AWS real. O plan resolve as AZs,

a AMI e as listas gerenciadas da conta e confirma que os **76 recursos** seriam criados sem erro. Para provisionar de fato:

```
cd infra/terraform
cp terraform.tfvars.example terraform.tfvars # grupo e owner
terraform init
terraform validate
terraform plan
terraform apply # ~20 min (RDS Multi-AZ e CloudFront são os mais lentos)
terraform destroy # ao final (deletion_protection do RDS precisa ser desligada antes)
```



Figura 2 — terraform validate e trechos do terraform plan (saída completa em docs/evidencias/terraform-plan.txt, com o ID da conta mascarado).

Categoria	Recursos no plan	Qtde.
Rede	VPC, 6 subnets, Internet Gateway, 2 Elastic IPs, 2 NAT Gateways, 4 tabelas de rota e 6 associações, VPC endpoint S3, NACL de dados	24
Segurança e identidade	3 security groups + 7 regras, chave KMS + alias, IAM role + policy + 2 anexos + instance profile, CloudTrail + bucket de logs (BPA, lifecycle, policy)	22
Armazenamento	Bucket de imagens (BPA, ownership, versionamento, SSE-KMS, lifecycle, policy OAC), RDS PostgreSQL Multi-AZ, parameter group, DB subnet group	10
Computação	Launch template, ALB, target group, listener, regra /admin, Auto Scaling Group, 2 políticas de escala	8
CDN	Distribuição CloudFront + Origin Access Control	2
Observabilidade e custos	Tópico SNS + assinatura, log group, 5 alarmes, AWS Budget	9
Auxiliar	Sufixo aleatório para os nomes globais dos buckets	1
Total		76

13. Riscos, Limitações e Próximos Passos

Risco / limitação	Impacto	Mitigação ou próximo passo
Ambiente não provisionado (validado só com plan)	Comportamento real em pico não demonstrado	<code>terraform apply</code> em janela curta + teste de carga com k6 ou hey para demonstrar o Auto Scaling (desafio bônus)
Trecho CloudFront → ALB em HTTP (sem domínio próprio)	Tráfego entre a borda e a origem sem cifra	Registrar domínio no Route 53, emitir certificado no ACM, listener 443 no ALB e <code>origin_protocol_policy = https-only</code>
Sem WAF	Exposição a bots, scraping e ataques de camada 7 no checkout	AWS WAF no CloudFront com regras gerenciadas (Core rule set, Bot Control, rate limit no login)
Região única (us-east-1)	Indisponibilidade regional derruba a loja	Cópia automática de snapshots para sa-east-1 + Terraform parametrizado por região (pilot light): RPO 24 h, RTO ~4 h
Dados pessoais fora do Brasil	Exige base legal de transferência internacional (LGPD art. 33)	Cláusulas-padrão (DPA da AWS) registradas pelo DPO; se exigido, migrar para sa-east-1 (+~60% de custo)
Banco como gargalo em 10x	Latência no checkout no pico	RDS Proxy (pool de conexões), read replica para o catálogo e ElastiCache para sessões e páginas quentes
NAT Gateway representa ~31% do custo	Custo fixo alto para pouco tráfego de saída	Avaliar um único NAT (seção 10.1) ou VPC interface endpoints conforme o volume
Aplicação de exemplo (nginx estático)	Não representa o e-commerce real	Pipeline de CI/CD gerando a AMI ou imagem da aplicação e fazendo deploy por instance refresh
Integração com as 120 lojas físicas	Estoque das lojas fora do e-commerce	Site-to-Site VPN ou integração via API Gateway

14. Referências

- AWS Well-Architected Framework — <https://docs.aws.amazon.com/wellarchitected/latest/framework/welcome.html>
- Amazon EC2 Auto Scaling, políticas de target tracking — <https://docs.aws.amazon.com/autoscaling/ec2/userguide/as-scaling-target-tracking.html>
- Amazon RDS Multi-AZ — <https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/Concepts.MultiAZ.html>
- Amazon RDS e AWS Secrets Manager — <https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/rds-secrets-manager.html>
- Amazon CloudFront, Origin Access Control para S3 — <https://docs.aws.amazon.com/AmazonCloudFront/latest/DeveloperGuide/private-content-restricting-access-to-s3.html>
- AWS-managed prefix lists (CloudFront origin-facing) — <https://docs.aws.amazon.com/vpc/latest/userguide/working-with-aws-managed-prefix-lists.html>
- AWS Pricing Calculator — <https://calculator.aws/>
- Terraform AWS Provider — <https://registry.terraform.io/providers/hashicorp/aws/latest/docs>
- Lei Geral de Proteção de Dados (Lei nº 13.709/2018) — https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm
- Resolução CD/ANPD nº 19/2024 — Regulamento de transferência internacional de dados
- Material da disciplina Computação em Nuvem — Prof. Bruno Cavalcanti, Pós-Graduação UNIFOR 2026.2